

Clase 250 — OSINT de personas

Parte: **12 — OSINT e ingeniería social** · Fuente: *Open Source Intelligence Techniques* (M. Bazzell) 

Duración estimada: **100 min** · Nivel: **Intermedio**

Objetivo

Aprender a construir un perfil OSINT de una persona a partir de identificadores públicos —nombre, correo, usuario, teléfono— usando pivoteo entre fuentes, siempre sobre objetivos autorizados o consentidos. El alumno terminará capaz de correlacionar cuentas, detectar reutilización de alias y producir un dossier verificable, entendiendo el impacto en la privacidad de estas técnicas.

Nota ética

El perfilado de personas se practica **solo sobre ti mismo, sobre un objetivo autorizado por escrito o sobre un compañero que consienta** en el ejercicio. Compilar datos de terceros sin base legal es doxing y puede ser delito. Trata cada dato personal como sensible.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Pivotar** entre nombre, correo, usuario y teléfono para enlazar cuentas de una misma persona.
2. **Verificar** la validez de correos y detectar brechas asociadas.
3. **Rastrear** la reutilización de un alias en múltiples plataformas.
4. **Evaluar** el nivel de confianza y evitar falsos positivos por homónimos.
5. **Redactar** un dossier con cadena de custodia y respeto a la privacidad.

Temas

#	Tema	Por qué importa
1	Identificadores y pivoteo	El correo enlaza cuentas dispersas
2	Búsqueda de nombres y homónimos	Evita atribuir datos a la persona equivocada
3	Enumeración de correos	Descubre cuentas y valida existencia
4	Alias/usernames cruzados	Un mismo nick suele repetirse
5	Números de teléfono	Enlazan mensajería y registros
6	Brechas de datos	Revelan contraseñas y patrones
7	Verificación y confianza	Separa hecho de inferencia

Definiciones y características

- **Pivoteo:** usar un dato hallado para descubrir otros (correo → usuario → perfiles). Característica: es la esencia del OSINT de personas.
- **Enumeración de correos:** confirmar si una dirección existe/está registrada en un servicio. Característica: pasiva si usa APIs públicas de recuperación.
- **Reutilización de alias:** tendencia de las personas a repetir el mismo nombre de usuario. Característica: alta tasa de éxito para correlacionar.
- **Homónimo:** dos personas con el mismo nombre. Característica: principal fuente de falso positivo.
- **Data breach / leak:** conjunto de credenciales expuestas por una brecha. Característica: útil para patrones, pero de manejo legal delicado.
- **Confianza (alta/media/baja):** grado de certeza de que un dato pertenece al objetivo. Característica: obliga a la verificación cruzada.

Herramientas y preparación

- **VM aislada** y sock puppet ya preparados (Clase 249).
- **Búsqueda de usuarios:** `sherlock`, `maigret`, `whatsmyname`. Instalación: `pipx install maigret`.
- **Correos:** Have I Been Pwned, Holehe (`pipx install holehe`), Hunter.io (con moderación).
- **Buscadores de personas:** solo de acceso público y legal según jurisdicción; documenta la fuente.
- **Recordatorio:** ejecuta cada herramienta contra tu propio identificador o el autorizado.

Laboratorio guiado

Objetivo: **tu propio identificador** (o el de un compañero que consienta).

1. Anota tus identificadores de prueba: nombre, un correo dedicado, un alias.
2. Busca el alias en múltiples plataformas: `sherlock tu_alias` y `maigret tu_alias`. Registra coincidencias reales vs. falsos positivos.
3. Comprueba en qué servicios está registrado un correo: `holehe correo@example.com`.
4. Consulta brechas asociadas al correo en Have I Been Pwned y anota qué datos se filtraron.
5. Pivota: si un perfil revela una web personal, extrae de ella nuevos correos o alias y repite.
6. Construye una tabla de correlación (dato, fuente, confianza, verificado sí/no).
7. Marca al menos un **homónimo** que aparezca y explica cómo lo descartaste (foto, ubicación, fecha).
8. Redacta un mini-dossier de 1 página con lo enlazado y su nivel de confianza.

Ejercicios

1. Ejecuta `sherlock` y `maigret` sobre el mismo alias y compara falsos positivos.
2. Explica por qué un "match" de usuario no prueba que sea la misma persona.
3. Documenta una cadena de pivoteo de al menos 3 saltos (correo → perfil → web → correo nuevo).
4. Analiza una brecha propia en HIBP y deriva 3 recomendaciones de higiene de credenciales.
5. Diseña criterios objetivos para descartar homónimos.
6. Investiga la diferencia legal entre OSINT autorizado y doxing en tu país.

Reto verificable

Entrega un **dossier de auto-OSINT** que enlace al menos 3 cuentas tuyas mediante pivoteo, con la cadena documentada y un nivel de confianza justificado por cada enlace. **Criterio de aceptación:** cada enlace es reproducible desde la fuente citada y el dossier incluye al menos un falso positivo descartado con criterio explícito.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Muchos perfiles falsos en Sherlock	La herramienta reporta 404 como match. Verifica cada uno manualmente.
Atribuir datos a la persona equivocada	Homónimo. Cruza con foto, ciudad o fecha antes de concluir.
Rate limit / bloqueo	Consultas masivas desde la misma IP. Espacia peticiones o usa la VM/VPN del alcance.
Correo "no encontrado" pero existe	El servicio oculta la enumeración. Prueba otro método pasivo.
Usar leaks robados como prueba	Fuente ilícita. Úsalos solo para patrones y según lo permita el engagement.

Preguntas frecuentes

 **¿Puedo perfilar a cualquiera con estas herramientas?** Técnicamente sí, legal y éticamente no. Solo sobre ti, con consentimiento o con autorización escrita en un engagement.

 **¿Un match de username es prueba definitiva?** No. Es un indicio. Necesitas corroboración cruzada (foto, biografía, enlaces) para elevar la confianza.

 **¿Qué hago si encuentro datos muy sensibles de mí?** Documenta, reduce tu exposición (elimina cuentas, cambia contraseñas, activa 2FA) y considera solicitudes de eliminación a los servicios.

Referencias

- Bazzell, M. *Open Source Intelligence Techniques*. <https://inteltechniques.com/book1.html>
- Sherlock. <https://github.com/sherlock-project/sherlock>
- Maigret. <https://github.com/soxoj/maigret>
- Holehe. <https://github.com/megadose/holehe>
- Have I Been Pwned. <https://haveibeenpwned.com/>

Siguiendo clase

Clase 251 - OSINT de empresas y dominios